

UNIVERSIDAD CATÓLICA DE SALTA
Tecnicatura en Seguridad Informática

CONTROL DE ACCESOS

TEMA 2 – CONTROL DE ACCESO (USUARIOS)

TRABAJO PRÁCTICO – PRIMERA PARTE

ISO/IEC 27701: gestión de la privacidad de la información

Grupo: 33
Año: 2026

Índice

- 1. Introducción
- 2. Material utilizado y criterio de trabajo
- 3. Marco conceptual
- 4. ISO/IEC 27701: concepto y finalidad
- 5. Relación con ISO/IEC 27001 e ISO/IEC 27002
- 6. Sistema de Gestión sobre la Privacidad de la Información (SGPI)
- 7. Responsables y encargados del tratamiento
- 8. Gestión de riesgos y mejora continua
- 9. Cuestionario: respuestas fundamentadas
- 10. Conclusión
- 11. Bibliografía y fuentes

1. Introducción

El presente trabajo corresponde a la primera parte del práctico del Tema 2 de la materia Control de Accesos. El material entregado propone estudiar la norma ISO/IEC 27701 y responder un cuestionario relacionado con la gestión de la privacidad de la información.

Aunque a primera vista privacidad y control de accesos pueden parecer temas separados, en la práctica están muy relacionados. Para proteger información personal no alcanza con saber que los datos existen: también es necesario controlar quién puede acceder, qué permisos tiene, qué acciones realiza y bajo qué condiciones se utiliza la información.

En esta primera parte se desarrolla el cuestionario de la cátedra y se incorporan explicaciones breves para justificar las respuestas. La intención es que el trabajo no quede como una simple lista de letras, sino que demuestre comprensión del tema.

2. Material utilizado y criterio de trabajo

Se utilizaron los materiales proporcionados para el práctico: el documento de la cátedra "Tema 2: Control acceso usuarios", el extracto de la UNE-EN ISO/IEC 27701:2021, material explicativo sobre ISO 27701, una nota de prensa de UNE y una guía de implantación de NQA.

La fuente normativa principal identifica a UNE-EN ISO/IEC 27701:2021 como una extensión de ISO/IEC 27001 e ISO/IEC 27002 para la gestión de privacidad de la información, con requisitos y directrices. (UNE, 2021, pp. 1–2).

El extracto también establece que la norma proporciona requisitos y orientación para implementar, mantener y mejorar continuamente un Sistema de Gestión sobre la Privacidad de la Información (SGPI), y que puede aplicarse a organizaciones de distintos tipos y tamaños. (UNE, 2021, p. 7).

La guía de NQA se utiliza como apoyo explicativo, especialmente para entender cómo se amplían los requisitos de seguridad y cómo se incorporan los riesgos de privacidad al análisis de riesgos.

3. Marco conceptual

El material de la cátedra presenta el control de acceso como un conjunto de medidas que incluye autenticación, autorización, controles físicos y lógicos, monitoreo y auditoría, gestión de sesiones, control de dispositivos y capacitación. Por eso, cuando hablamos de un usuario, no estamos hablando solamente de su contraseña.

En términos prácticos, el objetivo es que una persona pueda demostrar quién es, reciba solamente los permisos que necesita para realizar su tarea y que las acciones realizadas con esa identidad puedan ser controladas posteriormente.

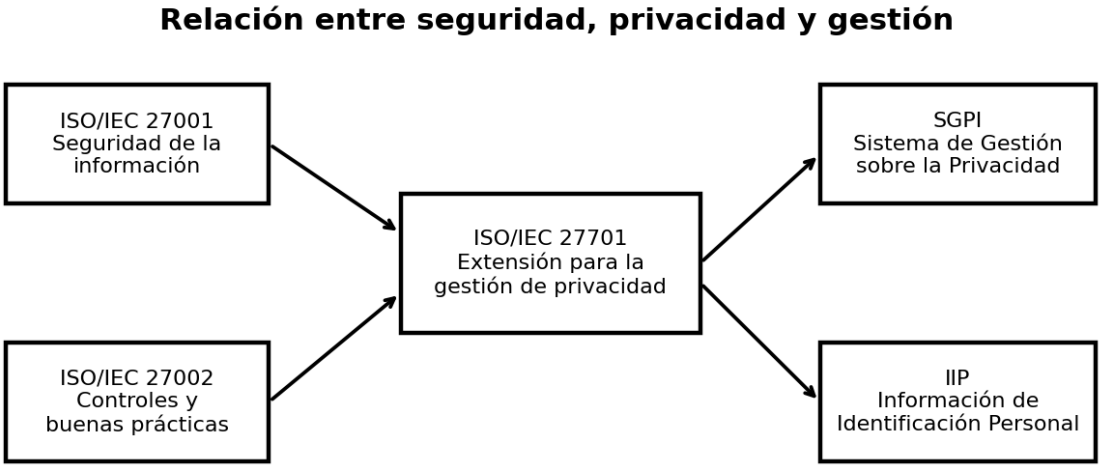


Figura 1. Relación conceptual entre seguridad, privacidad y gestión. Elaboración propia.

4. ISO/IEC 27701: concepto y finalidad

La ISO/IEC 27701 es una extensión de las normas ISO/IEC 27001 e ISO/IEC 27002 orientada a la gestión de la privacidad de la información. La denominación oficial del documento suministrado es "Técnicas de seguridad. Extensión de las Normas ISO/IEC 27001 e ISO/IEC 27002 para la gestión de privacidad de la información. Requisitos y directrices". (UNE, 2021, pp. 1–2).

Su finalidad no es reemplazar el sistema de gestión de seguridad de la información, sino ampliarlo para incorporar la perspectiva de privacidad. El extracto indica que la norma especifica requisitos relacionados con el SGPI y proporciona orientación para responsables y encargados del tratamiento de IIP. (UNE, 2021, p. 7).

Esto permite diferenciar dos cuestiones que muchas veces se mezclan: proteger técnicamente la información y garantizar que su tratamiento respete las condiciones de privacidad aplicables.

5. Relación con ISO/IEC 27001 e ISO/IEC 27002

La estructura del extracto muestra que la ISO/IEC 27701 incorpora requisitos específicos del SGPI relacionados con ISO/IEC 27001 y una guía específica relacionada con ISO/IEC 27002. También incluye una sección específica de control de acceso, donde aparecen los requisitos de negocio para el control de acceso, la gestión de acceso de usuario, las responsabilidades del usuario y el control de acceso a sistemas y aplicaciones.

Esto resulta particularmente relevante para Control de Accesos: la privacidad no elimina los controles de seguridad tradicionales, sino que agrega consideraciones específicas cuando la información tratada es información personal.

6. Sistema de Gestión sobre la Privacidad de la Información (SGPI)

El SGPI puede entenderse como el sistema de gestión mediante el cual una organización organiza, implementa, mantiene y mejora sus medidas relacionadas con la privacidad. La norma indica expresamente que busca permitir la implementación, mantenimiento y mejora continua de este sistema.

El índice de la norma muestra que el SGPI incluye contexto, liderazgo, política, roles y responsabilidades, planificación, recursos, competencia, concienciación, documentación, operación, evaluación del desempeño, auditoría interna, revisión por la dirección y mejora continua. Por lo tanto, no se trata solamente de instalar herramientas técnicas.

Desde el punto de vista de un estudiante de seguridad informática, esto se puede resumir de una manera bastante sencilla: hay que saber qué se protege, quién es responsable, qué riesgos existen, qué controles se aplican y cómo se verifica que esos controles siguen funcionando.

7. Responsables y encargados del tratamiento

La ISO/IEC 27701 diferencia entre responsables del tratamiento y encargados del tratamiento de información de identificación personal. El extracto señala que proporciona requisitos y orientación para ambos perfiles.

La guía de implantación complementa esta idea indicando que una organización debe determinar si actúa como controlador, procesador o ambos, y que los roles pueden quedar sujetos a conjuntos de controles diferentes. Esto muestra que la responsabilidad sobre los datos depende del papel que la organización desempeña.

En otras palabras, no todas las organizaciones que manipulan un dato personal necesariamente toman las mismas decisiones sobre él. Una puede determinar la finalidad del tratamiento y otra puede prestar un servicio siguiendo instrucciones.

8. Gestión de riesgos y mejora continua

La guía de implantación explica que deben evaluarse tanto los riesgos de seguridad de la información como los riesgos de privacidad relacionados con el procesamiento de información personal. También señala que la relación entre seguridad y privacidad debe gestionarse adecuadamente.

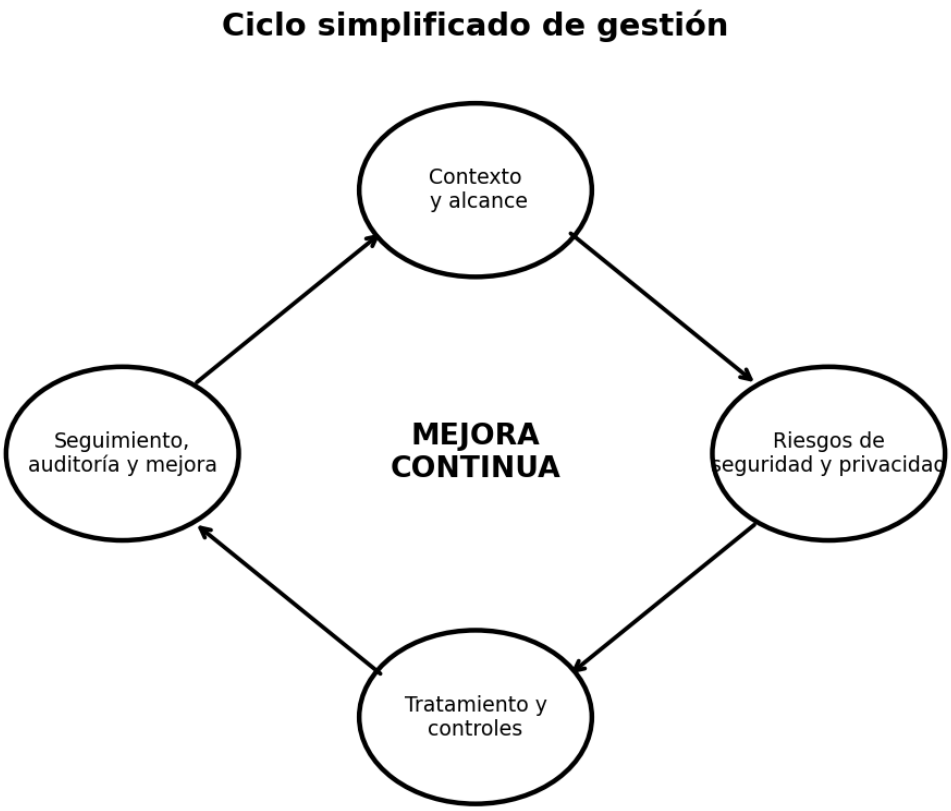


Figura 2. Ciclo simplificado de gestión. Elaboración propia a partir del enfoque de los materiales.

La estructura de la norma incluye monitorización, medición, análisis, evaluación, auditoría interna, revisión por la dirección, no conformidades, acciones correctivas y mejora continua. Por eso, la implementación debe entenderse como un proceso que se revisa y se ajusta, y no como una tarea que se hace una sola vez.

9. Cuestionario: respuestas fundamentadas

1. ¿Qué es ISO/IEC 27701?
Respuesta: b) Una extensión de ISO/IEC 27001 enfocada en privacidad.

Coincide directamente con el título y el objeto del documento normativo.

2. ¿Cuál es el objetivo principal?
Respuesta: b) Gestionar y proteger la privacidad de la información personal.

La norma está orientada al establecimiento, implementación, mantenimiento y mejora de un SGPI.

3. ¿Con qué normas se relaciona?
Respuesta: b) ISO/IEC 27001 e ISO/IEC 27002.

La propia denominación de la norma la presenta como extensión de ambas.

4. ¿Qué organizaciones pueden implementarla?
Respuesta: b) Organizaciones de cualquier tamaño y sector.

El campo de aplicación incluye organizaciones públicas, privadas, gubernamentales y sin fines de lucro, de distintos tamaños.

5. ¿Cuáles son las dos partes interesadas principales?
Respuesta: b) Responsables del tratamiento y encargados del tratamiento.

La norma proporciona requisitos y orientación para ambos perfiles.

6. ¿En qué se basa la implementación?
Respuesta: b) En ISO/IEC 27001.

La ISO/IEC 27701 amplía el sistema de gestión de seguridad de la información incorporando consideraciones de privacidad.

7. ¿Qué aspectos de privacidad son importantes?
Respuesta: b) Recolección, conservación y destrucción de datos personales.

El esquema de la norma contempla condiciones de recogida y tratamiento, conservación, eliminación y otros aspectos del ciclo de vida de la IIP.

8. ¿Qué tipo de controles contempla?
Respuesta: c) Controles operativos y de gestión de la privacidad.

Es la alternativa indicada por el cuestionario y resulta coherente con una norma que combina requisitos de gestión con controles y directrices.

9. ¿Qué riesgos deben analizarse?
Respuesta: b) Riesgos de privacidad y de seguridad de la información.

La guía de implantación distingue ambos tipos de riesgo y señala que su relación debe gestionarse adecuadamente.

10. ¿Cuál es el enfoque?
Respuesta: b) Proactivo y orientado a la mejora continua.

La mejora continua forma parte de la estructura del SGPI y el material complementario destaca el enfoque proactivo.

11. ¿Cuándo deben revisarse y actualizarse los controles?

Respuesta: c) Periódicamente, de acuerdo con cambios de la organización y su entorno.

El sistema incluye seguimiento, evaluación y mejora continua.

12. ¿Para qué sirven las auditorías internas?

Respuesta: a) Para asegurar la conformidad continua y la eficacia del SGPI.

La auditoría interna forma parte de la evaluación del desempeño del sistema.

13. ¿Cuál es un beneficio?

Respuesta: b) Mejorar la reputación de la organización en la gestión de privacidad.

El material complementario menciona confianza, transparencia y beneficios para la gestión de privacidad.

14. ¿Cuál es un desafío común?

Respuesta: a) Falta de personal capacitado.

La competencia y la concienciación forman parte de los elementos de apoyo del sistema de gestión.

15. ¿Cómo puede demostrarse la conformidad?

Respuesta: a) Mediante certificación por un organismo externo acreditado.

El material de apoyo presenta la certificación como una forma de demostrar cumplimiento; no debe confundirse certificación con la mera existencia de controles.

9.1 Resumen de respuestas

N.º	Respuesta	Concepto principal
1	B	Extensión de 27001 para privacidad
2	B	Gestión de privacidad
3	B	27001 y 27002
4	B	Distintos tamaños y sectores
5	B	Responsables y encargados
6	B	Base en 27001
7	B	Ciclo de vida de la IIP
8	C	Gestión y operación
9	B	Riesgos de seguridad y privacidad

10	B	Proactividad y mejora
11	C	Revisión periódica
12	A	Auditoría y eficacia
13	B	Confianza y reputación
14	A	Personal capacitado
15	A	Certificación externa

10. Conclusión

La lectura conjunta del material permite entender que ISO/IEC 27701 no es una norma separada de la seguridad informática, sino una extensión del enfoque de gestión de seguridad para incorporar de forma específica la privacidad de la información.

Para Control de Accesos, esto resulta importante porque proteger información personal requiere administrar identidades, permisos y controles, pero también considerar para qué se utilizan los datos, quién los trata, cuánto tiempo se conservan y qué responsabilidades existen.

En síntesis, el enfoque de la norma puede resumirse como una combinación de gestión, análisis de riesgos, controles, documentación, seguimiento y mejora continua. Esta base será útil para la segunda parte del práctico, donde se deberá plantear un procedimiento concreto para las altas, bajas y modificaciones de usuarios.

11. Bibliografía y fuentes utilizadas

- Universidad Católica de Salta. (2024). Tema 2: Control acceso (usuarios). Material de cátedra.
- Asociación Española de Normalización. (2021). UNE-EN ISO/IEC 27701:2021. Técnicas de seguridad. Extensión de las Normas ISO/IEC 27001 e ISO/IEC 27002 para la gestión de privacidad de la información. Requisitos y directrices.
- Applus+ Certification. (s. f.). ISO 27701 – Gestión de Información de Privacidad.
- NQA. (s. f.). Guía de implantación ISO/IEC 27701.



UNIVERSIDAD CATÓLICA DE SALTA
Tecnicatura en Seguridad Informática

CONTROL DE ACCESOS

TEMA 2 – CONTROL DE ACCESO (USUARIOS)

TRABAJO PRÁCTICO – SEGUNDA PARTE

Procedimiento para altas, bajas y modificaciones de usuarios

Alumno/Grupo:
Año: 2026

Índice

- 1. Introducción
- 2. Objetivo
- 3. Alcance
- 4. Fuentes y criterios utilizados
- 5. Principios generales del procedimiento
- 6. Roles y responsabilidades
- 7. Procedimiento de alta de usuarios
- 8. Procedimiento de modificación de usuarios
- 9. Procedimiento de baja de usuarios
- 10. Gestión de contraseñas y autenticación
- 11. Derechos de acceso y mínimo privilegio
- 12. Revisión periódica y auditoría
- 13. Registros y evidencias
- 14. Matriz de responsabilidades
- 15. Indicadores de control
- 16. Cursogramas
- 17. Conclusión
- 18. Bibliografía

1. Introducción

La segunda parte del trabajo tiene como finalidad transformar los conceptos estudiados en un procedimiento concreto para administrar usuarios dentro de una organización. La consigna de la materia solicita preparar un procedimiento para las altas, bajas y modificaciones de usuarios, teniendo en cuenta contraseñas y derechos de acceso.

Para elaborar el procedimiento se tomó como base principal el módulo de Control de Accesos de UCASAL y, como marco complementario, el material de ISO/IEC 27701 entregado para el práctico. Esta combinación resulta conveniente porque el módulo desarrolla con bastante detalle la administración de cuentas y derechos, mientras que la ISO/IEC 27701 aporta el enfoque de gestión de privacidad y su relación con ISO/IEC 27001 e ISO/IEC 27002.

2. Objetivo

Establecer un procedimiento formal, trazable y controlado para crear, modificar y revocar cuentas de usuario, procurando que cada persona tenga únicamente los accesos necesarios para cumplir su función.

El procedimiento busca reducir accesos no autorizados, evitar cuentas o permisos innecesarios y mantener evidencia de las decisiones tomadas. El módulo establece expresamente que el Responsable de Seguridad Informática debe definir un procedimiento formal de registro para otorgar y revocar acceso a sistemas, bases de datos y servicios multiusuario.

3. Alcance

Este procedimiento se aplica a usuarios internos, contratistas y, cuando corresponda, proveedores que necesiten acceder a sistemas, bases de datos, aplicaciones o servicios de información de la organización.

Comprende tres situaciones principales: alta de un usuario nuevo, modificación de sus derechos por cambio de función o necesidad, y baja cuando se revoca la autorización o finaliza la relación con la organización.

También alcanza las credenciales y mecanismos de autenticación asociados a la identidad, incluyendo contraseñas y, cuando existan, otros autenticadores.

4. Fuentes y criterios utilizados

La consigna del material de la materia indica expresamente que deben considerarse contraseñas y derechos de acceso. El módulo establece, entre otras cosas, el uso de identificadores únicos, autorización del Propietario de la Información, adecuación del nivel de

acceso a la función, entrega de los derechos por escrito, aceptación de condiciones, registro formal y cancelación inmediata de derechos en determinados casos.

El mismo módulo establece que los derechos de acceso deben revisarse formalmente a intervalos regulares de seis meses. También contiene pautas concretas sobre contraseñas, como mantenerlas en secreto, cambiarlas ante indicios de compromiso, evitar reutilizarlas y cambiar las provisionales en el primer inicio de sesión.

La ISO/IEC 27701, por su parte, incluye dentro de su estructura la gestión de acceso de usuario, responsabilidades del usuario y control de acceso a sistemas y aplicaciones. Por eso se utiliza como marco de referencia, sin reemplazar los requisitos operativos específicos indicados por el módulo.

5. Principios generales del procedimiento

Identificación individual: Cada usuario debe disponer de un identificador único. Los identificadores grupales solamente deberían utilizarse cuando exista una justificación operativa.

Autorización previa: La creación o modificación de acceso requiere la autorización correspondiente antes de habilitar los permisos.

Mínimo privilegio: El nivel de acceso debe ser adecuado para la función y no superior a lo necesario.

Segregación de funciones: Los accesos deben respetar la separación de tareas para evitar que una sola persona concentre controles incompatibles.

Trazabilidad: Toda alta, modificación o baja debe quedar registrada.

Revocación oportuna: Cuando un acceso deja de estar justificado, debe revocarse.

Confidencialidad de credenciales: Las contraseñas y demás credenciales deben mantenerse protegidas y no compartirse.

Revisión: Los permisos no deberían quedar indefinidamente sin control; el módulo establece revisión formal semestral.

6. Roles y responsabilidades

Actor	Responsabilidad	Momento principal
Área solicitante / RR.HH.	Informar el ingreso, cambio de función o desvinculación y aportar los datos necesarios.	Alta / modificación / baja

Propietario de la Información	Autorizar el uso del sistema o los datos y el nivel de acceso correspondiente.	Alta / modificación / revisión
Seguridad Informática	Definir y controlar el procedimiento, verificar condiciones de seguridad y revisar evidencias.	Todo el ciclo
Tecnología / Administrador	Crear, modificar, bloquear o revocar cuentas según la autorización recibida.	Implementación técnica
Usuario	Usar las credenciales de acuerdo con las reglas, mantenerlas secretas y comunicar incidentes.	Durante el uso
Auditoría / control	Revisar registros y cumplimiento cuando corresponda.	Control

7. Procedimiento de alta de usuarios

El alta comienza cuando existe una necesidad legítima de acceso. No se debería crear una cuenta solamente porque una persona pertenece a la organización; primero debe determinarse qué necesita hacer y qué información o sistemas requiere para realizar esa tarea.

7.1 Solicitud – El área solicitante comunica la incorporación del usuario y solicita los accesos necesarios. Se identifican nombre, función, área, sistemas requeridos y fecha de inicio.

7.2 Autorización – El Propietario de la Información verifica y autoriza el acceso correspondiente. La autorización debe existir antes de habilitar la cuenta.

7.3 Determinación del perfil – Se selecciona un rol o perfil compatible con la función. Se aplica mínimo privilegio y se verifica la separación de tareas.

7.4 Creación de identidad – Tecnología crea un identificador único para el usuario. Se evita que una misma persona utilice múltiples perfiles sin justificación.

7.5 Credenciales – Se asigna el mecanismo de autenticación correspondiente. Si se entrega una contraseña provisoria, el usuario debe cambiarla en el primer inicio de sesión.

7.6 Comunicación – Se informa al usuario cuáles son sus derechos y condiciones de acceso. El módulo contempla que se entregue un detalle escrito y que el usuario acepte las condiciones.

7.7 Registro – Se conserva evidencia de la solicitud, autorización, cuenta creada, perfil asignado y fecha de habilitación.

7.8 Habilitación – Una vez completados los pasos anteriores, se habilita el acceso. Si algún requisito de autorización no está completo, la cuenta no debería habilitarse.

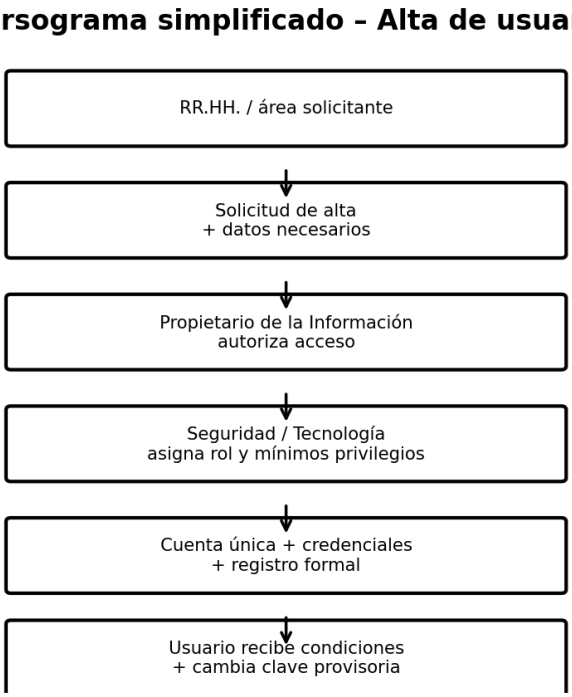


Figura 1. Cursograma simplificado del alta. Elaboración propia.

8. Procedimiento de modificación de usuarios

Una modificación ocurre cuando el usuario continúa vinculado con la organización pero cambia su función, área, responsabilidades o necesidad de acceso. El principio importante es que no se deben acumular permisos históricos.

8.1 Detección del cambio: El área correspondiente informa el cambio de función o necesidad.

8.2 Revisión de permisos existentes: Se revisan los accesos actuales para identificar cuáles siguen siendo necesarios y cuáles deben retirarse.

8.3 Autorización: Los nuevos accesos deben ser autorizados por el responsable correspondiente.

8.4 Aplicación: Tecnología modifica el perfil o los permisos. Los permisos que dejaron de corresponder se revocan.

8.5 Registro: Se registra qué cambió, quién lo autorizó, quién lo ejecutó y cuándo.

8.6 Verificación: Se comprueba que el nuevo perfil sea coherente con la función y con la separación de tareas.

9. Procedimiento de baja de usuarios

La baja requiere especial rapidez porque, una vez finalizada la necesidad de acceso, mantener una cuenta activa puede generar un acceso innecesario. El módulo indica que deben cancelarse inmediatamente los derechos cuando el usuario se desvincula, cambia sus tareas, pierde autorización o sus credenciales son comprometidas.

9.1 Notificación: RR.HH. o el área correspondiente comunica la desvinculación y la fecha/hora efectiva.

9.2 Bloqueo: Tecnología bloquea la cuenta en el momento definido por la política o por la situación concreta.

9.3 Revocación: Se revocan permisos, grupos, accesos remotos y otros mecanismos de autenticación asociados, según corresponda.

9.4 Credenciales y autenticadores: Se recuperan o invalidan tokens, tarjetas, dispositivos u otros autenticadores cuando existan.

9.5 Activos: Cuando corresponda, se recuperan equipos y otros recursos asignados al usuario.

9.6 Registro: Se documenta la baja y las acciones realizadas.

9.7 Revisión: Se verifica que no permanezcan cuentas o permisos redundantes.

Cursograma simplificado – Modificación y baja

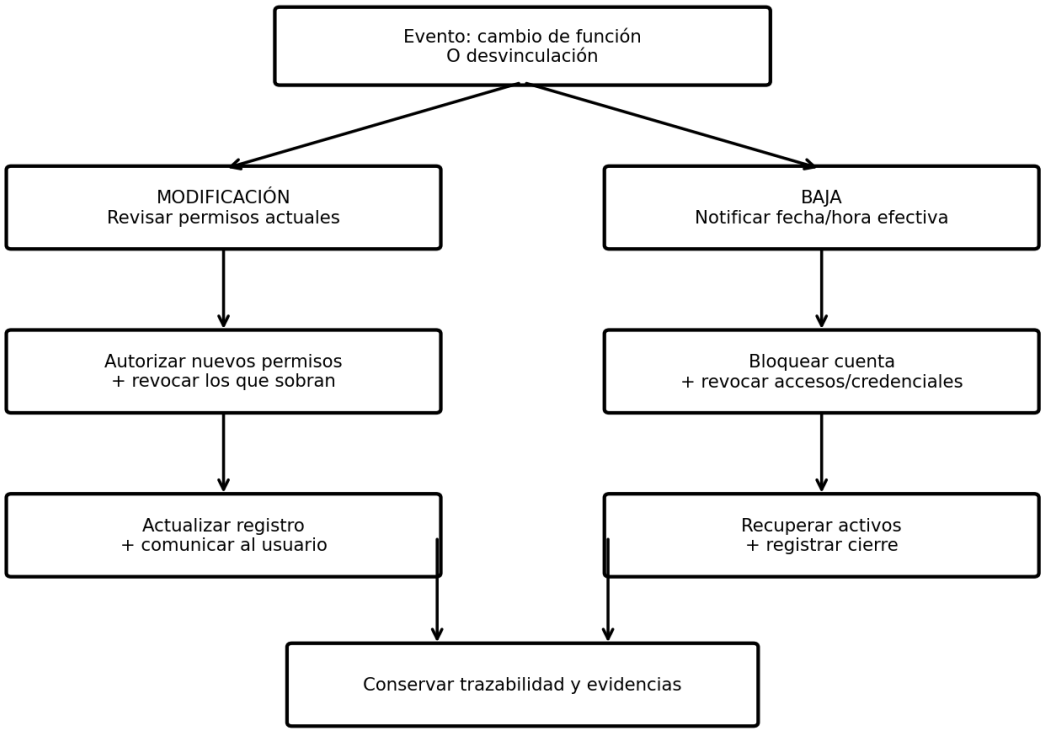


Figura 2. Cursograma de modificación y baja. Elaboración propia.

10. Gestión de contraseñas y autenticación

Las contraseñas constituyen un medio de validación de la identidad y, por lo tanto, están directamente relacionadas con los derechos de acceso. El módulo indica que deben existir contraseñas individuales y establece pautas de calidad y protección.

- Las contraseñas deben mantenerse en secreto.
- El usuario debe solicitar el cambio cuando exista indicio de compromiso.
- Deben evitarse datos personales fáciles de adivinar.
- No deben reutilizarse o reciclarse contraseñas antiguas.
- Las contraseñas provisionales deben cambiarse en el primer inicio de sesión.
- No deberían exponerse las contraseñas al ser ingresadas.
- Los sistemas deben gestionar adecuadamente los archivos o mecanismos donde se almacenan las contraseñas.
- Si se utilizan autenticadores físicos, debe existir un procedimiento para asignarlos, registrar al poseedor, recuperarlos al desvincularse y revocar su acceso ante un compromiso.

El objetivo no es solamente imponer una contraseña compleja, sino conservar la relación entre identidad, autenticación y responsabilidad sobre las acciones realizadas.

11. Derechos de acceso y mínimo privilegio

Los derechos de acceso deben estar relacionados con la función concreta del usuario. El módulo establece que el nivel otorgado debe ser adecuado para el propósito de la función y coherente con la política de seguridad, incluyendo la separación de tareas.

Por ejemplo, si una persona necesita consultar información para realizar su trabajo, no necesariamente necesita permisos para modificarla o eliminarla. De la misma manera, alguien que administra un sistema no debería recibir automáticamente permisos funcionales que no necesita.

El procedimiento propuesto, por lo tanto, evita la idea de “dar todos los permisos y después ver”. Primero se determina la necesidad, luego se autoriza y finalmente se implementa.

12. Revisión periódica y auditoría

El módulo establece una revisión formal de los derechos de acceso a intervalos regulares de seis meses. Esta revisión debe permitir detectar cuentas redundantes, permisos que ya no corresponden y situaciones derivadas de cambios de función.

Además, el sistema debe conservar registros suficientes para poder reconstruir quién solicitó, autorizó y ejecutó una modificación. Esta trazabilidad es importante tanto para seguridad como para auditoría.

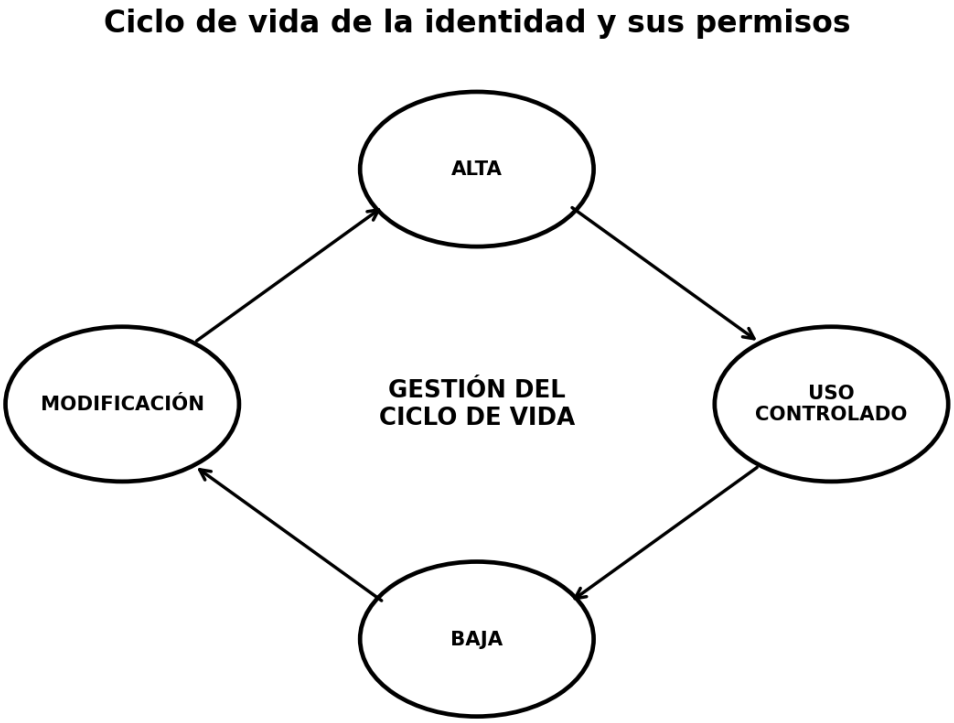


Figura 3. Ciclo de vida de la identidad y sus permisos. Elaboración propia.

13. Registros y evidencias

Registro	Contenido mínimo	Utilidad
Solicitud de alta	Usuario, función, área, sistemas solicitados, fecha	Justificar la necesidad
Autorización	Responsable que autoriza, fecha, alcance	Demostrar autorización
Cuenta/perfil	Identificador, rol, fecha de creación	Trazabilidad técnica
Modificación	Permisos retirados y agregados, motivo	Evitar acumulación de privilegios
Baja	Fecha/hora, cuenta bloqueada, accesos revocados	Demostrar revocación
Revisión semestral	Usuarios y derechos revisados, observaciones	Control periódico

Incidente de credenciales	Tipo de incidente y acción tomada	Responder a compromiso

14. Matriz de responsabilidades

Actividad	Solicita	Autoriza	Ejecuta	Controla
Alta	Área/RR.HH.	Propietario	Tecnología	Seguridad
Modificación	Área/RR.HH.	Propietario	Tecnología	Seguridad
Baja	RR.HH./Área	Responsable correspondiente	Tecnología	Seguridad
Revisión de derechos	Propietario	Propietario	Tecnología	Seguridad/Auditoría
Credenciales comprometidas	Usuario	Responsable correspondiente	Tecnología	Seguridad

15. Indicadores de control

Como propuesta para evaluar si el procedimiento funciona, pueden utilizarse indicadores sencillos. No se presentan como requisitos adicionales de la norma, sino como una forma práctica de controlar el procedimiento.

- Porcentaje de altas realizadas con autorización previa.
- Cantidad de cuentas sin responsable identificado.
- Cantidad de cuentas redundantes detectadas en la revisión semestral.
- Tiempo transcurrido entre la notificación de una baja y la revocación del acceso.
- Cantidad de usuarios que mantienen permisos que ya no corresponden a su función.
- Cantidad de incidentes relacionados con pérdida, robo o compromiso de credenciales.

16. Cursogramas

Los diagramas incluidos muestran una versión simplificada del procedimiento. En una implementación real podrían incorporarse responsables concretos, sistemas de tickets, firmas electrónicas, aprobaciones y niveles de criticidad.

El punto importante es que ninguna de las tres situaciones —alta, modificación o baja— debería resolverse únicamente mediante una orden informal. La existencia de solicitud, autorización, ejecución y registro permite mantener trazabilidad.

17. Conclusión

La administración de usuarios constituye una parte central del control de accesos porque determina quién puede ingresar a los recursos de información y con qué nivel de privilegios. Un procedimiento formal permite evitar que las cuentas se creen sin autorización, que los permisos se acumulen con el tiempo o que permanezcan activos accesos correspondientes a personas que ya no los necesitan.

El procedimiento desarrollado combina los aspectos concretos indicados por el módulo de Control de Accesos —identificación única, autorización, mínimo privilegio, segregación de funciones, contraseñas, revocación y revisión semestral— con el enfoque de gestión y privacidad relacionado con ISO/IEC 27701.

Como conclusión, el control de usuarios no debería verse como una tarea aislada del administrador de sistemas. Es un proceso que involucra a las áreas que solicitan, a quienes autorizan, a Tecnología que implementa, a Seguridad que controla y al propio usuario que debe proteger sus credenciales. La trazabilidad entre esas etapas es lo que permite que el acceso sea controlado y demostrable.

18. Bibliografía

- Universidad Católica de Salta. (2024). Control de Accesos: Material de Unidad II. Material de cátedra.
- Universidad Católica de Salta. (2024). Tema 2: Control acceso (usuarios). Material de cátedra.
- Asociación Española de Normalización. (2021). UNE-EN ISO/IEC 27701:2021. Técnicas de seguridad. Extensión de las Normas ISO/IEC 27001 e ISO/IEC 27002 para la gestión de privacidad de la información. Requisitos y directrices.